LAB WORKSHEET

Phishing Analysis Lab

Recognise, analyse and report phishing emails like a security analyst.

Red flags

- The display name doesn't match the real address; look-alike domains (`oakfie1d.test`, `0akfield.test`).
- Links whose text hides the real destination. Read the domain **from the right**: in `password.oakfield.test.account-verify.example` the owner is `account-verify.example`.
- Urgency, threats, payment or bank-detail changes, unexpected attachments (`.pdf.exe`, `.docm`, `.zip`), QR-code lures.

Email headers

- **Received** chain: read bottom-up to find where the email started.
- **Reply-To** on another domain (invoice and CEO fraud). **Return-Path**.
- **Authentication-Results**: `spf=`, `dkim=` (is `d=` the From domain?), `dmarc=`, `p=none`.
- **X-Originating-IP**, Message-ID domain.
- Passing SPF, DKIM and DMARC doesn't mean safe: a look-alike domain can pass all three.

What to do

Report it with **Report Phishing**. If you clicked or entered details, tell IT straight away and change the password.

Independent task

Triage 12 reported emails for Brightwater Housing Trust (fictional): phishing or legitimate, with red flags and one header indicator for each phish. Pass: 10/12, including all the dangerous ones.

Instructor: Aaron Cocker-Swanick